

vulnerabilidades XSS y CSRF en aplicaciones web

Las vulnerabilidades de seguridad en aplicaciones web representan una de las mayores amenazas para la integridad, confidencialidad y disponibilidad de la información. Entre las más comunes y peligrosas se encuentran el Cross-Site Scripting (XSS) en sus variantes reflejado y almacenado, así como el Cross-Site Request Forgery (CSRF). Ambos tipos de ataques tienen como característica principal el aprovechamiento de la confianza del navegador, ya sea en el contenido recibido o en la identidad del usuario autenticado, y su explotación puede derivar en consecuencias graves como robo de credenciales, secuestro de sesiones, manipulación de datos o control remoto del navegador.

El XSS reflejado, también conocido como *non-persistent XSS*, ocurre cuando una aplicación web incluye datos proporcionados por el usuario dentro de la respuesta HTML sin una validación o codificación adecuada, permitiendo la ejecución directa de scripts maliciosos en el navegador de la víctima. Este tipo de ataque se basa en engañar a la víctima para que acceda a una URL especialmente construida. En esa URL se incrusta un payload JavaScript que el servidor reflejará sin filtrado, de modo que el navegador lo interpretará como parte legítima del código del sitio. La ejecución no queda almacenada en el servidor; su impacto depende de la interacción del usuario y por tanto tiene un alcance más limitado en persistencia, pero puede ser igualmente crítico si es combinado con técnicas de *social engineering* o ataques *phishing*. La debilidad fundamental radica en que el valor ingresado no es saneado, y los navegadores interpretan etiquetas como `<script>` como código legítimo del documento, incluso si provienen de parámetros de entrada. Este tipo de vulnerabilidad compromete la política de confianza entre el navegador y la fuente de origen, lo que puede conducir a ataques de *session hijacking*, redirecciones no deseadas o robo de información sensible.

El XSS almacenado o *stored XSS*, en cambio, representa una amenaza aún más crítica. Se produce cuando un payload malicioso es persistido en el servidor, por ejemplo, al ser insertado en un campo de entrada como comentarios, nombres de usuario o mensajes. Posteriormente, cada vez que otros usuarios visualizan el contenido almacenado, el script se ejecuta automáticamente en sus navegadores. Este tipo de ataque no requiere engañar al usuario con enlaces externos, lo que lo vuelve más insidioso y efectivo, especialmente en sistemas donde múltiples usuarios interactúan con datos compartidos. El almacenamiento del script en la base de datos o el sistema de archivos hace que su impacto tenga un alcance temporal indefinido, ejecutándose cada vez que la información comprometida es cargada en el cliente. Las posibles consecuencias incluyen el robo masivo de cookies, explotación de sesiones autenticadas, manipulación de interfaces gráficas (*UI redressing*) o incluso movimientos laterales dentro del sistema a través de privilegios escalados.

Por su parte, el ataque CSRF explota la confianza de un sitio web en el navegador del usuario autenticado. Consiste en inducir al navegador de un usuario legítimo a enviar una petición no autorizada, pero válida, a una aplicación en la que ya está autenticado. CSRF no explota una vulnerabilidad del navegador sino del diseño de la aplicación, al no verificar adecuadamente el origen de las peticiones. Así, si un usuario inicia sesión en un sitio vulnerable y luego visita un sitio malicioso, este puede desencadenar una acción

involuntaria, como el cambio de contraseña, transferencia de fondos o eliminación de datos, sin el consentimiento del usuario. Esta clase de ataque se vale de formularios HTML ocultos, scripts automáticos o incluso imágenes con atributos manipulados. Mientras el navegador envía cookies de sesión de manera automática al dominio correspondiente, la aplicación receptora no distingue si la petición fue iniciada de forma legítima o maliciosa. Por este motivo, los ataques CSRF son especialmente peligrosos en escenarios donde el usuario tiene privilegios administrativos o capacidades de modificación crítica.

La defensa contra estas vulnerabilidades requiere múltiples capas de seguridad. En el caso de XSS, se deben aplicar estrategias combinadas como la validación rigurosa de entrada del lado del servidor, la codificación contextual de salida según el medio de representación (HTML, JavaScript, atributos, URLs), y la implementación de cabeceras HTTP de seguridad como **Content-Security-Policy (CSP)**, que restringen la ejecución de scripts arbitrarios. También es crucial emplear frameworks modernos que manejan automáticamente la sanitización y el escape de contenido dinámico, reduciendo la exposición a errores manuales.

Para mitigar ataques CSRF, es fundamental implementar tokens anti-CSRF (también conocidos como *synchronizer tokens* o *double submit cookies*) que sean únicos por sesión y por acción crítica, y que se verifiquen en cada solicitud sensible. Además, se debe evitar el uso de métodos HTTP inseguros (como GET para acciones que modifican estado) y configurar políticas de validación de origen y referer que permitan identificar si una petición proviene de un entorno autorizado. Otras medidas como la habilitación de cabeceras **SameSite** en cookies y la segmentación de privilegios por tipo de usuario pueden reforzar la defensa contra estas amenazas.

En resumen, tanto el XSS reflejado como el almacenado, y los ataques CSRF, representan vectores de ataque que aprovechan la confianza inherente del navegador y la falta de controles en aplicaciones web mal diseñadas. Conocer sus mecanismos de funcionamiento, sus diferencias operativas y sus implicancias prácticas es esencial para desarrollar aplicaciones seguras, realizar auditorías efectivas y diseñar políticas de prevención que protejan la integridad de los sistemas y la privacidad de los usuarios. El profesional de ciberseguridad debe entender no solo cómo se explotan estas vulnerabilidades, sino cómo se integran en campañas de ataque más amplias y cómo pueden ser mitigadas de manera proactiva desde las fases tempranas del desarrollo.